



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-41089 Windows Netlogon RCE

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-03
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-41089 Windows Netlogon RCE - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-03 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-41089 Windows Netlogon RCE

Reconstruction Note

This markdown source was reconstructed from the published PDF in `RAIcoon\_Reports` and then cleaned into a canonical source-built report during analyst-kit standardization. The original editable source was not recovered from the public repository.

1. Executive Summary

CVE-2026-41089 is a critical remote code execution vulnerability in Windows Netlogon. Microsoft describes the issue as a stack-based buffer overflow that can allow an unauthorized attacker to execute code over a network. The vulnerability carries a CVSS v3.1 base score of 9.8 and should be treated as a tier-0 risk wherever Windows domain controllers are in scope.

The defensive significance is not just the score. Netlogon is central to Active Directory trust and authentication workflows, so successful exploitation on a domain controller can quickly become a domain-wide or forest-wide incident. Even where exploitation has not been confirmed in a specific environment, defenders should frame response planning around the possibility of SYSTEM-level code execution on a domain controller.

At publication time, Microsoft marked the issue as not publicly disclosed, not exploited, and "Exploitation Less Likely." Later public reporting cited the Centre for Cybersecurity Belgium as warning that exploitation had been observed in the wild. CISA KEV was not listing the issue when this report checked the feed on 2026-06-03.

Confirmed facts:

- CVE ID: CVE-2026-41089
- Vendor: Microsoft
- Component: Windows Netlogon / Netlogon Remote Protocol
- Impact: Remote Code Execution
- CWE: CWE-121 Stack-based Buffer Overflow
- CVSS v3.1: 9.8 Critical
- CVSS vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Microsoft release date: 2026-05-12
- Highest-priority exposure class: Windows domain controllers

Analyst assessment:

- Treat this as an emergency domain-controller patch and monitoring issue.
- Prioritize domain controllers first, then other exposed Windows Server systems in scope.
- If exploitation is suspected, begin AD-compromise response rather than ordinary single-host triage.

2. Vulnerability Metadata

Key metadata:

- CNA / Vendor: Microsoft
- Published by vendor: 2026-05-12
- NVD last modified at report time: 2026-05-15
- Release train: Microsoft 2026-May
- Vulnerability class: Stack-based buffer overflow
- Attack vector: Network
- Attack complexity: Low
- Privileges required: None
- User interaction: None
- Scope: Unchanged
- Confidentiality / Integrity / Availability impact: High / High / High

Affected products called out in the reconstructed source include:

- Windows Server 2012
- Windows Server 2012 R2
- Windows Server 2016
- Windows Server 2019
- Windows Server 2022
- Windows Server 2022 23H2
- Windows Server 2025
- Server Core variants where applicable

Operational implications:

- Customer action is required.
- Reboot is required.
- Exposure on domain controllers materially increases enterprise risk.

3. Source Review & Confidence

Primary-source basis:

- Microsoft MSRC vulnerability record for the canonical title, severity, exploitability rating, and remediation framing.
- Microsoft affected-product API for product scoping.
- Microsoft Security Update Guide for patch and update context.

Secondary-source basis:

- NVD for normalization and external scoring context.
- CISA KEV feed for exploit-listing status at the time of review.
- Public reporting from Help Net Security for the claim that exploitation had been observed.
- MITRE ATT&CK and CWE references for taxonomy and defensive mapping.

Confidence assessment:

- High confidence in the basic vulnerability facts, severity, and affected-product scope because those points come from Microsoft and NVD.
- Medium confidence in exploitation-status interpretation because the reconstructed report combines Microsoft exploitability language with later public reporting and a KEV point-in-time check.
- Medium confidence overall because the original editable report was not recovered and the markdown source was reconstructed from the published PDF.

4. Vulnerability Details

Microsoft describes CVE-2026-41089 as a Windows Netlogon remote code execution vulnerability caused by a stack-based buffer overflow. The practical concern is that Netlogon sits in a critical authentication and trust path for Active Directory environments, especially where servers act as domain controllers.

A remote, unauthenticated network path combined with domain-controller exposure creates a high-consequence scenario:

- Successful code execution may occur before any user interaction.
- Compromise of a domain controller can enable rapid privilege escalation and identity abuse.
- Post-exploitation activity may include credential dumping, directory access, service creation, or policy manipulation.

This is not merely a patch-compliance issue. For many organizations it is a domain-resilience issue.

5. Attack Scenarios

Scenario 1: External or partner-network reachability to an exposed domain controller

- An attacker identifies reachable RPC/SMB/Netlogon paths.
- A specially crafted request targets a vulnerable Netlogon implementation.
- Successful exploitation results in code execution on a domain controller.

Scenario 2: Internal foothold followed by domain-controller exploitation

- An attacker already has access to a workstation, VPN session, or adjacent server.
- The attacker pivots toward a vulnerable domain controller using internal reachability.
- The objective is fast escalation from local compromise to domain compromise.

Scenario 3: Partial exploit attempt with operational side effects

- An attacker or exploit developer causes Netlogon instability without full reliable execution.
- Defenders may observe service disruption, crash behavior, or unusual RPC/SMB traffic before clear post-exploitation signals appear.

6. Threat Landscape & Exploitation Status

The report's reconstructed evidence supports three important points:

- Microsoft initially rated exploitation as less likely.
- Microsoft did not mark the issue as exploited at the time reflected in the report.
- Later public reporting cited observed exploitation in the wild.

That mix should not be read as reassuring. In practice, defenders should assume that:

- a public exploit path may emerge quickly,
- opportunistic internal exploitation is plausible once details spread,
- domain-controller vulnerabilities deserve accelerated remediation even before KEV listing.

CISA KEV absence at the review date does not materially reduce operational urgency.

7. Affected Products and Exposure

Highest-priority exposure classes:

- Tier-0 domain controllers
- Domain-joined Windows servers that expose relevant RPC/SMB/Netlogon surfaces
- Legacy or exception-based servers with slower patch cycles
- Server Core deployments that may be missed by casual inventory reviews

Questions defenders should answer immediately:

- Which domain controllers are still vulnerable?
- Which systems are externally reachable or broadly reachable over VPN?
- Which servers remain on Server 2012 / 2012 R2 or other exception-heavy populations?
- Which environments lack complete telemetry from DC system logs, process telemetry, and network visibility?

Useful local pivots:

- Inventory systems with the `domain-controller` host role.
- Review exposure related to TCP 445 and adjacent RPC dependencies.
- Validate compensating controls if patching cannot be completed immediately.

8. Mitigation and Workarounds

Immediate actions:

- Patch every affected domain controller with the applicable Microsoft security update.
- Reboot patched systems and verify they returned cleanly to service.
- Produce an exception list for any domain controller that cannot yet be patched.
- Confirm that DC RPC/SMB/Netlogon surfaces are not reachable from the internet, guest networks, or unnecessarily broad VPN pools.

Short-term hardening:

- Tighten segmentation around domain controllers.
- Restrict administrative paths into tier-0 systems.
- Review privileged access paths and break-glass handling.

- Validate that DC logging reaches SIEM and EDR.

Workaround note:

- The reconstructed report does not provide a safe substitute workaround that removes the need to patch. Defensive teams should not treat segmentation alone as remediation.

9. Detection Engineering

Detection priorities:

- Netlogon or related service instability on domain controllers
- Unusual RPC/SMB traffic directed at DCs
- Suspicious process creation or service creation on DCs
- Signs of post-exploitation activity involving credential access, directory access, or privilege manipulation

Recommended telemetry:

- Windows System and Security logs from domain controllers
- Directory Service logs where available
- Sysmon or equivalent process and service telemetry
- Network telemetry for RPC/SMB concentration around DCs

Practical analytic themes:

- Burst or anomalous RPC connections to DCs
- Service crashes or repeated restart patterns affecting Netlogon-adjacent services
- New processes spawned in unusual sequences on DCs
- Administrative follow-on activity shortly after anomalous inbound traffic

10. Threat Hunting

Hunt objectives:

- Identify vulnerable systems that also show unusual inbound RPC/SMB activity.
- Look for DC service instability near the vulnerability disclosure and patch window.
- Search for suspicious child processes, new services, shadow-copy activity, or credential-access behavior on DCs.
- Review privileged-group changes, GPO changes, and other tier-0 modifications after suspicious activity.

Suggested hunt questions:

- Which domain controllers received unusual inbound traffic patterns before patching?
- Did any DC produce System events consistent with service failure or crash behavior?
- Were there anomalous logons, remote execution patterns, or directory-replication style actions after suspicious traffic?
- Are there signs of DCSync, ntds.dit access, or service-based persistence after the disclosure date?

11. MITRE ATT&CK Mapping

Mapped ATT&CK techniques from the supporting artifact:

- T1210 - Exploitation of Remote Services
- Rationale: Remote exploitation path against Windows Netlogon on domain controllers.
- T1003.003 - OS Credential Dumping: NTDS
- Rationale: Post-compromise domain credential access risk highlighted in the report.

Interpretation:

- T1210 captures the initial remote exploitation concern.
- T1003.003 captures one of the most dangerous likely post-exploitation objectives in an AD environment.

12. Validation / Lab Testing

Safe validation steps:

- Confirm all domain controllers and affected servers have the correct KB or fixed build.
- Validate event collection from DC System, Security, Directory Service, and Sysmon/EDR logs.
- Test detection content with benign service-restart simulations only during maintenance windows.
- Use a lab domain to validate log collection and query behavior.

Recommended validation checklist:

1. Run ``Get-ADDomainController -Filter *`` and inventory OS versions.
2. Run ``Get-HotFix`` checks for relevant KBs.
3. Confirm fixed build numbers match or exceed the Microsoft affected-product guidance.
4. Confirm service-failure events reach SIEM.
5. Confirm process telemetry from DCs reaches EDR/SIEM.
6. Confirm firewall and NDR visibility for TCP 135, 445, and dynamic RPC to DCs.
7. Run a tabletop exercise for a domain-controller RCE scenario.

Do not validate by sending malformed Netlogon requests to production domain controllers.

13. Recommended Actions Summary

Critical - AD / Infrastructure - 24 hours

- Patch all domain controllers with the applicable May 2026 Microsoft update and reboot.
- Verify fixed builds and produce an exception list for any unpatched DC.

Critical - AD / Infrastructure - 24 hours

- Confirm domain-controller RPC, SMB, and Netlogon surfaces are not reachable from the internet, guest networks, or broad VPN pools.

Critical - Network Security - 24 hours

- Add or validate segmentation controls around TCP 135, 445, and dynamic RPC paths to domain controllers.

High - SOC - 24 to 48 hours

- Deploy hunts for Netlogon service instability, anomalous RPC or SMB to DCs, and suspicious DC process creation.

High - IR - 24 to 48 hours

- Prepare a domain-controller compromise playbook, including KRBTGT reset planning, privileged credential rotation, and tier-0 isolation steps.

High - Identity / AD - 72 hours

- Review domain-admin and privileged-group changes since 2026-05-12.

Medium - Vulnerability Management - 1 week

- Validate patch coverage for Server 2012 / 2012 R2 ESU systems and Server Core variants.

Medium - Security Engineering - 1 week

- Add DC network segmentation baselines and exception review for core RPC exposure.

Medium - GRC - 2 weeks

- Document risk acceptance for any domain controller that cannot be patched immediately and require compensating controls.

If exploitation is suspected:

- Isolate the affected DC from nonessential network access while preserving evidence.
- Preserve volatile evidence where possible.
- Assume tier-0 compromise until disproven.
- Rotate privileged credentials and plan KRBTGT reset if compromise indicators are confirmed.

- Review DCSync, ntds.dit access, shadow copies, new services, GPO changes, and privileged-group modifications.

14. References

- Microsoft MSRC API, `CVE-2026-41089 Windows Netlogon Remote Code Execution Vulnerability`
- <https://api.msrmicrosoft.com/sug/v2.0/en-US/vulnerability/CVE-2026-41089>
- Microsoft Security Update Guide
- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-41089>
- Microsoft affected product API for CVE-2026-41089
- [https://api.msrmicrosoft.com/sug/v2.0/en-US/affectedProduct?\\$filter=cveNumber%20eq%20%27CVE-2026-41089%27](https://api.msrmicrosoft.com/sug/v2.0/en-US/affectedProduct?$filter=cveNumber%20eq%20%27CVE-2026-41089%27)
- NVD CVE detail page
- <https://nvd.nist.gov/vuln/detail/CVE-2026-41089>
- CISA Known Exploited Vulnerabilities catalog
- Exact URL should be restored if recovered from the original source material.
- Help Net Security reporting on exploitation
- <https://www.helpnetsecurity.com/2026/06/01/windows-netlogon-rce-exploited-cve-2026-41089/>
- MITRE ATT&CK T1210 `Exploitation of Remote Services`
- <https://attack.mitre.org/techniques/T1210/>
- MITRE ATT&CK T1003.003 `OS Credential Dumping: NTDS`
- <https://attack.mitre.org/techniques/T1003/003/>
- MITRE CWE-121 `Stack-based Buffer Overflow`
- <https://cwe.mitre.org/data/definitions/121.html>

Refresh notes:

- Re-check MSRC for revisions, known issues, and replacement KBs before executive distribution.
- Re-check CISA KEV because listing status may change quickly.
- Replace any placeholder DC names in hunt content with local inventory before deployment.